GreenLeaf Microfinance

INCIDENT RESPONSE POLICY

ISO/IEC 27001:2022 | Draft Version 1.0

Document Owner: Information Security / GRC Lead (Proposed)

Approval Authority: GreenLeaf Management (Proposed)

Effective Date: Pending Approval

Review Frequency: Annually or following significant security incidents

Approval Status: Draft for Educational Simulation

1. Purpose

The purpose of this Incident Response Policy is to establish a structured process for identifying, reporting, assessing, containing, investigating, and recovering from information security incidents affecting GreenLeaf Microfinance.

The policy aims to minimize disruption to financial services, protect sensitive borrower information, preserve relevant evidence, and support timely security incident resolution.

This policy supports ISO/IEC 27001:2022 Annex A controls A.5.24 (Information Security Incident Management Planning and Preparation), A.5.25 (Assessment and Decision on Information Security Events), A.5.26 (Response to Information Security Incidents), A.5.27 (Learning from Information Security Incidents), and A.5.28 (Collection of Evidence).

2. Scope

This policy is intended to apply to all GreenLeaf Microfinance employees, contractors, developers, administrators, and authorized third-party service providers.

Covered systems and information include:

- GreenLeaf's web portal and planned Android application.
- Borrower records and sensitive financial information.
- Cloud infrastructure, databases, and application servers.
- Administrative accounts, authentication systems, and security logs.
- Development, testing, and production environments.

Security events covered by this policy include suspected unauthorized access, credential compromise, data exposure, malware infections, service disruptions, and other activities that may threaten the confidentiality, integrity, or availability of GreenLeaf information.

The current GreenLeaf environment is a fictional training sandbox. This policy describes proposed procedures and does not establish that an operational incident response capability has already been implemented.

3. Roles and Responsibilities

GreenLeaf Management: Approves the Incident Response Policy, provides resources, and authorizes major response decisions.

Information Security / GRC Lead: Coordinates incident response activities, maintains the incident register, assigns severity levels, and oversees reporting and remediation.

Incident Response Team: Investigates incidents, coordinates containment, preserves evidence, supports recovery, and documents response activities.

System Administrators: Collect relevant system logs, isolate affected infrastructure when authorized, and implement approved technical remediation measures.

Application Developers: Investigate application vulnerabilities, implement security fixes, and validate application functionality following remediation.

Department Managers: Coordinate operational communications and ensure affected staff follow response instructions.

Employees and Contractors: Report suspected security incidents promptly and preserve potentially relevant information without conducting unauthorized investigations.

These responsibilities are proposed organizational roles for the fictional GreenLeaf environment and require formal assignment before implementation.

4. Incident Identification and Reporting

All employees, contractors, and authorized third parties shall promptly report suspected information security incidents through the designated reporting channel.

Reports should include, when available:

- Date and time of discovery.
- Affected systems, applications, or accounts.
- Description of the suspicious activity.
- Potentially affected borrower or financial information.
- Relevant error messages, screenshots, or system logs.
- Actions already taken.

The Information Security / GRC Lead shall ensure that reported events are recorded in an incident register and assessed to determine whether they qualify as information security incidents.

Incident reports shall be handled confidentially, and relevant records shall be preserved for investigation.

ISO References: A.5.24, A.5.25

Related Task 4 Remediation: Establish an approved incident management plan defining responsibilities, escalation procedures, incident reporting, and response testing.

5. Incident Classification and Severity

GreenLeaf Microfinance shall classify security incidents according to their potential impact on borrower information, financial services, and organizational operations.

Critical: Confirmed large-scale exposure of sensitive borrower information, widespread ransomware, or major compromise of critical systems.

High: Confirmed unauthorized access to sensitive systems, significant malware infections, or serious disruption of essential services.

Medium: Suspicious account activity, limited security incidents, or vulnerabilities with a credible possibility of exploitation.

Low: Minor security events with limited impact and no confirmed compromise of sensitive information.

The Information Security / GRC Lead shall assign an initial severity level and reassess it as new evidence becomes available.

ISO Reference: A.5.25

6. Incident Escalation and Communication

All suspected incidents shall be reported promptly to the designated Information Security / GRC Lead.

Critical and High incidents shall be escalated immediately to GreenLeaf Management and the designated Incident Response Team.

The Incident Response Team shall maintain an incident record documenting the incident classification, affected systems, response decisions, responsible personnel, and communications.

External communications, including notifications to affected borrowers, regulators, law enforcement, or service providers, shall be coordinated through authorized management and appropriate legal or compliance personnel.

Notification obligations and deadlines shall be determined according to applicable laws, contracts, and the nature of the incident.

ISO References: A.5.24, A.5.26

7. Incident Containment and Investigation

The Incident Response Team shall assess the incident and select containment measures proportionate to the risk and operational impact.

Possible containment actions include:

- Disabling compromised accounts or revoking affected credentials.
- Isolating compromised servers or application components.
- Restricting vulnerable application endpoints.
- Blocking suspicious network connections.
- Preserving relevant logs and system information.

Containment actions shall be documented and approved by the designated incident authority, except where preauthorized emergency procedures permit immediate action.

Investigations shall establish the incident timeline, affected assets, suspected cause, potential information exposure, and scope of compromise.

ISO Reference: A.5.26

8. Evidence Collection and Preservation

Evidence collected during an incident shall be handled in a manner that supports integrity, traceability, and authorized access.

Relevant evidence may include:

- Authentication and access logs.
- Application and server logs.
- Firewall and network security records.
- Incident reports and investigation notes.
- System configuration records.
- Relevant screenshots and approved forensic captures.

Each evidence item shall be documented with its source, collection date and time, collector, storage location, and relevant integrity information.

Access to collected evidence shall be restricted to authorized personnel. Evidence transfers and handling activities shall be recorded to maintain an appropriate chain of custody.

Evidence retention shall follow applicable legal, contractual, and organizational requirements.

ISO Reference: A.5.28

Related Task 4 Remediation Actions: Establish incident assessment criteria, document response decisions, create incident response playbooks, and define procedures for collecting and protecting evidence.

9. Incident Eradication and Recovery

Following containment, the Incident Response Team shall identify and remove the underlying cause of the incident.

Recovery activities may include:

- Removing malicious software and unauthorized access mechanisms.
- Resetting compromised credentials and reviewing affected permissions.
- Applying security patches and correcting vulnerable configurations.
- Restoring systems and information from verified backups.
- Testing restored applications before returning them to normal operation.

The designated system owner shall approve the restoration of affected services after appropriate security validation.

Recovery actions, restoration times, and outstanding risks shall be documented in the incident register.

ISO References: A.5.26, A.5.30

10. Post-Incident Review and Lessons Learned

Following the resolution of significant incidents, the Information Security / GRC Lead shall coordinate a documented post-incident review.

The review shall identify the incident's root cause, response effectiveness, operational impact, communication issues, and opportunities for improvement.

Corrective actions shall be assigned to responsible personnel with proposed completion dates.

Relevant lessons learned shall be incorporated into security procedures, employee awareness activities, and the organizational risk register.

ISO Reference: A.5.27

11. Incident Response Testing and Training

GreenLeaf Microfinance shall conduct periodic incident response exercises to evaluate the effectiveness of its proposed procedures.

Exercises may include tabletop simulations involving unauthorized access, borrower data exposure, ransomware, and service disruption.

The Information Security / GRC Lead shall document exercise scenarios, participants, observations, and corrective actions.

Employees and contractors shall receive incident reporting awareness appropriate to their responsibilities.

ISO References: A.5.24, A.6.3

12. Policy Review and Compliance

This policy shall be reviewed at least annually and following significant security incidents, major system changes, or relevant changes in legal and contractual requirements.

The Information Security / GRC Lead shall coordinate policy reviews and submit proposed revisions for management approval.

Compliance with the policy shall be assessed through incident records, response exercises, evidence reviews, and remediation tracking.

Exceptions shall require documented justification, risk assessment, designated approval, and a defined review or expiration date.

ISO References: A.5.1, A.5.36

13. Related Remediation Actions and Approval

This policy supports the following findings from the GreenLeaf Task 4 gap analysis:

- **A.5.24**: Approve an incident management plan with assigned responsibilities, escalation procedures, and periodic testing.
- **A.5.25**: Define event assessment criteria and maintain documented incident classification decisions.
- **A.5.26**: Establish incident response playbooks and conduct tabletop exercises.
- **A.5.27**: Record lessons learned and track corrective actions following incidents.
- **A.5.28**: Define evidence collection, preservation, and chain-of-custody procedures.
- **A.5.30**: Define recovery objectives and test ICT recovery arrangements.

Document Version: 1.0 (Draft)

Document Owner: Information Security / GRC Lead (Proposed)

Approval Authority: GreenLeaf Management (Proposed)

Approval Status: Pending

This policy is intended for an educational simulation. It does not represent a formally approved incident response program or demonstrate operational effectiveness at a real financial institution.